

ai-m（当前二开项目）本地工作流平台

两轮对抗式审查与整改报告

审查对象： 1.0 版开发手册及样例

整改版本： 2.0

审查日期： 2026-07-12

方法： 第一性原理、红队攻击路径、故障注入、兼容性逆向推演、性能与维护成本审查

严重程度： P0（阻断级）、P1（高危）、P2（中危）、P3（一般）

1. 总结

第一轮发现 5 个阻断级、8 个高危、14 个中危和 2 个一般问题。整改后进行第二轮攻击，又发现 4 个阻断级、11 个高危和 6 个中危问题。全部问题已按严重程度排序，并落实到主手册、结构约束、数据库、威胁模型、迁移方案、部署样例和自动校验工具。

2.0 版不再追求最小改动。它将“增加本地模型”重新定义为建设一个受控执行平台：

浏览器与执行凭据分离；

网页请求与持久工作进程分离；

逻辑任务与外部尝试分离；

工作流源码、编译绑定与发布修订版分离；

外部临时输出与项目工件分离；

后端、资源池与生成配置分离；

安全策略与工作流作者声明分离。

2. 第一轮审查：按严重程度排序

P0-01（阻断级）：浏览器保存密钥和后端地址

隐藏副作用： 跨站脚本可读取全部供应商密钥；用户可篡改地址让服务端访问本机、局域网或云元数据；多人部署时普通用户可修改公共执行后端；密钥进入浏览器同步、备份和崩溃报告。

根因： 把界面配置、执行凭据和物理后端建模为同一个浏览器对象。

整改： 建立服务端 ExecutionBackend（执行后端）和密钥引用；普通任务只传生成配置编号；地址解析、端口、重定向和网段执行白名单；旧浏览器密钥采用安全迁移并立即清除。

验证： 浏览器存储、普通接口和日志中搜索不到真实密钥；非管理员不能修改后端；任意地址字段被拒绝；服务端请求伪造负向测试通过。

P0-02（阻断级）：长任务依赖网页进程和进程内锁

隐藏副作用： 热更新、滚动部署或崩溃导致任务失联；多进程同时占用显卡；网页请求超时；应用重启后任务永久运行中。

根因： 没有独立执行领域和持久资源所有权。

整改： 独立工作进程；数据库原子领取；持久租约；资源池槽位；防旧写令牌；恢复扫描；优雅关闭。

验证： 杀死网页进程不影响外部任务；杀死工作器后新工作器接管；旧工作器恢复后写入被拒绝。

P0-03（阻断级）：提交不确定窗口被错误当成幂等重试

隐藏副作用： 服务端已接收任务但响应丢失时，自动重试会生成两份昂贵结果；用户可能被重复计费；角色资源被无序覆盖。

根因： 把本地幂等键误认为跨网络副作用的恰好一次保证。

整改：提交前持久化关联编号；经行为探测后为生产后端预分配外部任务编号；提交禁用自动重试和重定向；响应丢失进入对账；证据不足进入人工处理。

验证：假后端模拟接受后断线，系统不创建第二个外部任务；相同编号可恢复；后端忽略编号时阻止启用。

P0-04（阻断级）：大媒体整块读入内存

隐藏副作用：多个视频、音频或高分辨率图片并发会触发内存耗尽、进程崩溃和重复执行；恶意后端可用无限响应攻击工作器。

根因：把图片演示代码扩展为通用媒体基础设施。

整改：全程流式传输；逐块限额和摘要；首字节和总时限；暂存文件；安全解码；同文件系统原子提交或对象存储提交协议。

验证：超限流在达到上限时中止；慢速流超时；视频不产生与文件大小相当的额外堆内存。

P0-05（阻断级）：任意工作流和自定义节点被当作普通模板

隐藏副作用：自定义节点可读文件、访问网络、执行命令和窃取素材；预览和说明也可能成为攻击载体。

根因：忽略了工作流供应链的代码执行属性。

整改：隔离上传、限额解包、静态扫描、平台节点策略、固定提交摘要、环境验证、冒烟测试、双人审查、只读发布和撤销机制。

验证：危险节点、未知节点、符号链接、路径穿越、解压炸弹和环境漂移均被阻止。

P1-01（高危）：用 modelId（模型编号）表示工作流

风险：命名误导，后续条件分支错误，无法表达后端、工作流和参数版本。

整改：引入执行后端、工作流包修订版和生成配置修订版；界面文字可保留“模型”，内部不复用旧字段。

P1-02（高危）：把外部执行字段塞入旧业务任务表

风险：业务重试、模型重试和归档重试混淆，状态机不可维护。

整改：新增逻辑任务、执行尝试、工件、资源池和事件表；旧业务任务只通过关系表关联。

P1-03（高危）：把外部历史当系统最终事实

风险：外部历史可被清空、延迟或被其他客户端修改；历史存在也不代表工件已归档。

整改：内部数据库是逻辑事实；外部历史只作证据；成功必须完成工件提交。

P1-04（高危）：无条件使用全局中断

风险：在共享后端误杀其他用户或任务。

整改：行为探测按任务取消；共享后端禁止全局中断；专用后端也需确认当前任务和持有租约。

P1-05（高危）：进程内互斥锁保护显卡

风险：多进程、重启和多服务失效。

整改：数据库资源池槽位、租约和单调防旧写令牌。

P1-06（高危）：每任务实时连接和固定轮询

风险：连接风暴、轮询风暴和数据库写放大。

整改：每后端共享连接；事件分派与去重；阶段化轮询；进度合并写。

P1-07（高危）：状态机过于简单

风险：下载失败触发重跑模型；取消与完成竞态覆盖结果；不确定提交被误判失败。

整改：分层状态机和阶段化重试，明确不确定、收集、提交和人工处理状态。

P1-08（高危）：任务执行依赖实时默认配置

风险：排队期间管理员修改默认模型，重试使用不同工作流，历史不可复现。

整改：任务创建时冻结不可变执行快照和全部修订版摘要。

P2-01（中危）：结构约束允许未知字段

整改：核心对象拒绝未知字段，限制长度、数量和范围；负向夹具验证。

P2-02（中危）：业务代码依赖节点编号

整改：作者清单使用语义选择器，安装时编译为固定节点编号；运行时验证摘要。

P2-03（中危）：源码目录与发布目录边界不清

整改：源码、隔离、测试和只读发布目录分离；生产只按摘要读取。

P2-04（中危）：每任务获取完整节点信息

整改：按环境指纹缓存，优先按节点类查询；环境变化才刷新。

P2-05（中危）：只看模型文件名判断兼容

整改：环境锁包含引擎、运行时、自定义节点、模型摘要和输入结构。

P2-06（中危）：输出前缀来自用户

整改：系统生成不透明前缀，并限制到任务暂存命名空间。

P2-07（中危）：随机种子使用普通网页脚本数字

整改：以十进制字符串或大整数保存，并做范围验证。

P2-08（中危）：固定分辨率忽略显存和工作流倍数

整改：生成配置定义比例、像素、倍数和设备基准策略。

P2-09（中危）：仅根据扩展名和响应媒体类型判断输出

整改：魔数、限制解码、尺寸和时长验证，必要时重编码。

P2-10（中危）：远程后端缺少传输与网络策略

整改：局域网强制传输加密、认证、证书校验、地址白名单和无重定向。

P2-11（中危）：预览、说明和压缩包缺少内容安全

整改： 限额解包；预览安全重编码；说明纯文本或净化；拒绝链接型文件。

P2-12（中危）：数据库并发边界未定义

整改： 单主机预写式日志、短事务、忙等待、事件合并；明确迁移服务型数据库的触发条件。

P2-13（中危）：所有错误统一重试

整改： 输入、契约、环境、连接、提交不确定、执行、收集、提交和安全错误分别处理。

P2-14（中危）：占位工作流看起来像生产文件

整改： 夹具明确标记冒烟用途；生产工作流必须从真实环境导出并晋级。

P3-01（一般）：在没有真实设备基准前承诺固定成功率和延迟

整改： 改为验收方法、服务级目标建立流程和设备基准，不在架构文档承诺未经测量的数字。

P3-02（一般）：术语混用

整改： 统一术语表，文件、数据库、接口和界面映射明确。

3. 第二轮审查：攻击整改后的方案

R2-P0-01（阻断级）：密钥迁移流程本身可能泄漏

攻击路径： 为方便自动迁移，页面把旧密钥发送到普通接口；反向代理、请求日志、性能追踪或错误报告保存请求正文。

二次整改： 默认要求管理员重新录入；自动迁移仅使用短期一次性端点、再认证、禁止正文日志、立即清除本地值和密钥轮换提示。

R2-P0-02（阻断级）：租约没有防旧写仍会双提交

攻击路径： 工作器甲租约过期，工作器乙接管；甲网络恢复并提交旧状态，覆盖乙结果。

二次整改： 资源槽位使用永不回退的防旧写令牌；所有续租、提交、工件和状态写入都条件检查令牌；槽位释放不删除记录、不重置序号。

R2-P0-03（阻断级）：配置声称支持客户端任务编号但实际后端忽略

攻击路径： 旧版本、代理或定制服务接受字段却重新生成编号，响应丢失后无法对账。

二次整改： 后端启用前进行行为探测：提交无害工作流、验证响应编号、历史编号和重复语义；探测结果绑定环境指纹；不通过则禁止生产配置使用强恢复模式。

R2-P0-04（阻断级）：原子重命名跨文件系统不成立

攻击路径： 暂存位于容器临时盘，最终目录位于挂载盘；重命名退化为复制，中途终止留下半文件。

二次整改： 暂存位于最终目标同一文件系统；启动时验证设备编号；对象存储使用暂存键和条件提交；跨设备时使用复制、校验、同步和提交标记协议。

R2-P1-01（高危）：后端能力缓存可能陈旧

二次整改： 探测结果绑定环境指纹、过期时间和失败失效；环境或节点摘要变化立即禁用相关配置。

R2-P1-02（高危）：按节点标题绑定可能同名或翻译变化

二次整改： 选择器组合标题、节点类和输入字段；必须唯一；推荐工作流作者使用稳定唯一标签；编译结果锁定工作流摘要。

R2-P1-03（高危）：工作流摘要不等于环境可复现

二次整改： 增加环境锁和模型摘要；验证报告记录实际运行环境；升级后重新冒烟。

R2-P1-04（高危）：取消与完成竞态

二次整改： 在事务中按阶段和工件提交位点裁决；取消意图不删除已提交工件；界面区分“已请求取消”和“已确认取消”。

R2-P1-05（高危）：错误和日志快照泄漏私有内容

二次整改： 结构化安全错误、字段白名单、路径归一化、提示词摘要、密钥脱敏、私有诊断访问控制和保留期。

R2-P1-06（高危）：文档、数据库和结构约束命名漂移

二次整改： 统一为执行后端、工作流包修订版、生成配置修订版、生成任务、执行尝试和工件；自动交叉引用检查。

R2-P1-07（高危）：工作流包可自行提供拒绝正则

攻击路径： 被审查对象修改或放宽审查策略，或利用灾难性正则耗尽审查进程。

二次整改： 平台安全策略独立版本化；工作流只声明需求；不执行作者提供的正则或代码。

R2-P1-08（高危）：把 ComfyUI（本地工作流引擎）编号语义硬编码到通用尝试表

二次整改： 通用表使用提交关联编号、外部编号策略和可选外部任务编号；适配器决定编号语义；同步适配器和云端异步适配器不被迫伪造客户端编号。

R2-P1-09（高危）：长期运行的推理实例可读取同一输入根目录中的其他任务

攻击路径： 即使项目目录没有直接挂载，只要多个项目的暂存输入同时出现在同一工作流输入根目录，恶意或失陷节点仍可枚举和读取其他任务素材。

二次整改： 把执行后端定义为文件系统安全租户边界；第一阶段资源槽并发为一，工作进程只把当前任务复制到后端专用摄取目录并在受控时点清理；跨用户强隔离采用独立实例、独立目录或按任务短生命周期容器。部署样例不再把通用任务暂存卷直接挂载给推理实例。

R2-P1-10（高危）：通用传输函数可能被滥用调用全局破坏性接口

攻击路径：工作流服务还提供队列清空、历史删除、用户数据写入等接口。若适配器暴露任意路径和方法，业务漏洞可能升级为清空全局状态或修改执行环境。

二次整改：传输层只暴露固定类型化方法；网关按方法和路径白名单；生成凭据不能调用管理接口；全局清理能力独立授权、审计和二次确认。

R2-P1-11（高危）：工作领取租约和显卡资源租约混用会造成错误释放与陈旧写

二阶问题：一个工作器负责推进任务，不等于它仍然拥有显卡槽位。把两个租约都叫 lease（租约）并存入执行尝试，会让续租、接管和释放逻辑互相覆盖。

二次整改：生成任务保存工作领取者、领取到期和领取防旧写令牌；资源槽位独立保存资源租约和资源防旧写令牌；状态写和外部副作用分别检查对应令牌；字段命名禁止含糊。

R2-P2-01（中危）：合法结构仍可资源耗尽

二次整改：平台安全策略限制节点数、连边数、像素、批量、文本长度、输出数、运行时限和内存预算；按后端基准收紧。

R2-P2-02（中危）：实时连接重连导致事件重复或乱序

二次整改：连接代次、任务事件去重键、单调进度快照、历史对账和幂等状态转换。

R2-P2-03（中危）：单机数据库的高频事件阻塞业务

二次整改：进度合并、事件抽样、短事务、单写入边界和迁移触发条件；不把每个节点进度写入主任务行。

R2-P2-04（中危）：容器仍挂载完整上传目录

二次整改：任务专用输入暂存；只复制授权文件；图片、声音和视频实例使用独立目录；声音样本默认只读和私有。

R2-P2-05（中危）：生成配置修订版可原地修改

二次整改：修订版数据库触发器禁止更新和删除；启用、可见性、废弃和撤销放到状态表。

R2-P2-06（中危）：第三方客户端事件语义与官方服务变化不同步

二次整改：第三方库被隔离在传输适配器；固定版本；契约测试；保留原生参考实现；升级必须通过行为探测和假后端矩阵。

4. 第二轮通过门槛

- ☒ 浏览器不持有密钥和任意后端地址；
- ☒ 长任务由独立工作进程执行；
- ☒ 工作领取租约与资源槽位租约分离，且两者都有防旧写令牌；
- ☒ 客户端任务编号由行为探测证明；

- ☒ 文档不宣称跨系统恰好一次；
 - ☒ 提交不确定有独立状态和人工流程；
 - ☒ 共享后端禁止危险全局中断；
 - ☒ 外部历史只是证据；
 - ☒ 输入输出流式、限额、哈希和原子提交；
 - ☒ 推理实例输入根目录具有明确的安全租户边界；
 - ☒ 传输层只允许固定接口白名单；
 - ☒ 工作流按可执行供应链工件管理；
 - ☒ 平台安全策略不由工作流作者控制；
 - ☒ 不可变修订版由数据库和流程共同保证；
 - ☒ 归档失败不触发模型重跑；
 - ☒ 测试覆盖进程终止、断线、历史清空、乱序、磁盘满、数据库锁和取消竞态；
 - ☒ 原漫剧云端流程有兼容适配和回归门槛；
 - ☒ 数据库、结构约束、样例和文档命名一致。
-

5. 整改文件映射

全量架构与执行： AI-M_ComfyUI_本地工作流平台开发执行手册_v2.0.md

双轮问题与证据： AI-M_ComfyUI_对抗式双轮审查报告_v2.0.md

安全威胁： SECURITY_THREAT_MODEL.md

迁移与回滚： MIGRATION_AND_ROLLBACK.md

实施门槛： IMPLEMENTATION_CHECKLIST.md

架构决策： adrs/（架构决策目录）

严格结构约束： examples/schemas/（结构约束目录）

配置和数据库示例： examples/config/（配置目录）

正向与负向夹具： examples/fixtures/（测试夹具目录）

自动校验： tools/validate_examples.py（样例校验工具）

加固部署： examples/docker-compose.hardened.example.yml（加固部署样例）

6. 最终意见

根源性修复的判断标准不是代码行数，而是责任边界是否正确：

凭据属于服务端控制平面；

长任务属于持久执行平面；
外部引擎不是业务数据库；
工作流属于受信供应链；
工件必须经系统校验与提交；
不可判定副作用必须保守处理；
历史任务必须冻结执行契约；
原漫剧兼容必须由测试证明。

在这些基础完成前，不应把任何本地图片、声音或视频工作流接入正式业务入口。完成后，Z-Image（造相文生图模型）、IndexTTS2（声音克隆模型）和 OmniVoice（多语言声音模型）只是同一执行平台上的不同能力，不再需要三套互不兼容的补丁。